Information Security

Lecture 1: Foundations of Information Security

A textbook treatment

Based on the lectures, TPs and quiz of Imane Fouad

October 25, 2026

Contents

How to read this book **2**

1 Foundations of Information Security **3**

1.1 Precision, Properties, Risk 3

1.2 Services and Controls 5

1.3 Actors and Attack Classes 6

1.4 Malware by Mechanism 6

1.5 Domains, Access Control, GRC 8

How to read this book

Each concept in this book is presented in the same rhythm, and every section closes with a *Go deeper* box (the exact details, numbers and edge cases a demanding examiner asks about) followed by *Hard questions, answered.*

1. **Motivation and intuition.** Why do we care? What problem does the idea solve, and what picture should you hold in your head?
2. **Formal statement.** The precise definition or theorem, set in a coloured box so it is easy to find when revising.
3. **Proof.** Every claim is proved. Longer proofs are split into labelled steps, and the one idea that makes the proof work is isolated in a *Key insight* box.
4. **Interpretation and discussion.** What the result really says, where it applies, and which misreadings to avoid.
5. **Examples.** From "trivially small" to "genuinely useful."
6. **Techniques, classic problems and gotchas.** Computational shortcuts, proof patterns, exam favourites with one-line solutions, and the mistakes everyone makes once.

Margin notes carry the informal, "say it out loud" version of what is happening in the main text. Every major section opens with a *What are we trying to get?* box that states the goal in one breath before any mathematics, and closes with a summary box.

Prerequisites. Comfort with binary and hexadecimal, elementary probability, and the modular arithmetic of integers; everything else (finite fields for AES, the number theory behind RSA, Shannon entropy) is built where it is needed.

Chapter 1

Foundations of Information Security

1.1 Precision, Properties, Risk

"Secure" is a relation: secure against what*, for* which asset*, with respect to* which property.

"Is this circle secure?" has no answer; "if I flood-fill outside it, does colour get in?" does, and the answer depends on whether the boundary is closed. Every security claim must name an asset, a property, an adversary's capability and the control that preserves the property; and the control must be built systematically, since a freehand boundary has gaps. The course's numbers justify three later design choices: $\approx 90\%$ of attacks involve human error (so controls must bound the cost of a mistake), a breach costs on average \$3.86M, and takes 191 days to detect (so detection is not optional).

Definition 1.1.1 (Security properties (ISO 27001))**.** *Information security is the preservation of confidentiality, integrity and availability; authenticity, accountability, non-repudiation and reliability can also be involved.* **Confidentiality**: information is not made available or disclosed to unauthorised individuals, entities or processes. **Integrity**: data or resources are not improperly changed, deleted or corrupted; *data* integrity (records unaltered) vs *system* integrity (programs, configurations, processes intact). **Availability**: accessible and usable upon demand by an *authorised* entity. **Authentication**: user or data origin accurately identifiable. **Accountability**: actions traceable to those responsible. **Non-repudiation**: an actor cannot later deny an action to a third party (stronger than authentication, which only convinces the receiver).

Reading the formula

To find the broken property, find the *object* the attacker touched and what the system assumed about it. Airport: Eve forges a boarding pass in her own name for a ticket bought in Alice's name; the pass–record check is skipped; the pass, a trusted document, was altered: *integrity*. Targeted ads on private browsing: *confidentiality*. Platform crash before a deadline: *availability*, no adversary required. The properties are independent: each can fail alone.

Example 1.1.2 (Eve attacks Acme)**.** (1) Phishing yields a valid username/password: confidentiality of the credential, and authentication is under-

mined. (2) Buffer overflow injects code into a root process: system integrity (and the actor's authentication). (3) Database logging disabled: accountability. (4) A new DB user created by editing the user table: integrity of authorisation data, authentication. (5) DDoS takes the server down (availability) while the database is copied (confidentiality). Name properties, not techniques, and name all of them.

Definition 1.1.3 (Risk; threat model)**. Asset**: what we protect. **Threat**: something that can cause damage. **Vulnerability**: an exploitable weakness. **Risk**: the potential that a threat exploits a vulnerability and harms an asset. Jim Anderson: security is "a well-informed sense of assurance that the information risks and controls are in balance". A **threat model** fixes (i) the asset, (ii) the vulnerability assumed and defended against, (iii) the attacker's capabilities and knowledge; only then can a defence be said to *prevent*, *detect*, *respond to* or *recover from* the attack. HTTP: asset = communications incl. credentials; vulnerability = packets in clear on open Wi-Fi; attacker = can intercept a user's or the site's packets; control = HTTPS. Risk treatment has four options: treat, accept, transfer (insurance), avoid.

Key insight

Risk needs both a threat and a vulnerability: the same unpatched service is a risk on the Internet and none on an isolated machine. A control is judged *inside* its model: HTTPS answers interception, not phishing.

Go deeper: the details an examiner asks about

- Quiz 1 Q1–3 are one-property scenarios: read without change (C), alter while accessible (I), DoS (A).
- "Upon demand by an authorised entity": an over-aggressive lockout that refuses legitimate users breaks availability.
- Authentication has two senses in the course: user authentication (access control) and data-origin authentication (MACs, signatures); the ISO wording covers both.
- Adversaries are parameters: a behavioural advertiser, Guccifer 2.0 (leaked DNC documents), and the NSA's own adversary Snowden (the insider).

Hard questions, answered

Q. A stolen backup tape is encrypted. Which properties are affected?
A. Confidentiality preserved (strong cipher, safe key); availability of that copy lost (the organisation's availability depends on other copies); integrity of the original untouched.

Q. Why is non-repudiation not implied by authentication?
A. With a shared secret Bob is convinced Alice sent the message, but Bob could have forged it; a judge cannot distinguish. Non-repudiation needs something only Alice can produce: a signature.

Q. Threat model for a stolen password database?
A. Asset: passwords/accounts (C). Vulnerability: verifiers in the attacker's hands. Attacker: unlimited offline guessing with dictionaries. Control: per-user salt + slow hash (Chapter 5). Out of scope: observing passwords at login.

1.2 Services and Controls

Definition 1.2.1 (Service vs control; the two classifications)**.** A **service** (goal, property) is *what* we want: C, I, A, accountability, authentication. A **control** (mechanism) is *how*: encryption, firewalls, training. By implementation: **physical** (guards, locks, monitoring, environmental, physical intrusion detection), **technical** (logical access control, cryptography, security devices, authentication, network IDS, forensics), **administrative** (policies, standards, procedures, personnel screening, awareness training). By function: **preventive** (stops exploitation: encryption, firewall, MFA), **detective** (warns: IDS, cameras, log review), **corrective** (repairs after detection: restoring a known-good image).

Reading the formula

Every control gets *both* labels. Speed round: MFA = technical/preventive; firewall = technical/preventive; cameras = physical/detective; phishing training = administrative/preventive; restoring backups = technical/corrective; IDS alert = technical/detective. The same word can live in two categories (a motion sensor is physical IDS; a network sensor is technical); one control can serve two functions (a logging firewall); and a control can be wrong for a service (encryption gives C, not A: ransomware is encryption against availability). Depth: controls of different categories so one failure is caught by another.

Go deeper: the details an examiner asks about

- Backup = preparation; the *restore* is the corrective act; classify by the action named.
- The three statistics map to the three functions: human error undermines prevention, 191 days is the absence of detection, $3.86M is what correction limits.

Hard questions, answered

Q. Classify: guard checking badges; morning log review; lockout after 5 failures; password-rotation policy; disaster-recovery site.
A. Physical/preventive; administrative/detective; technical/preventive; administrative/preventive; technical (or physical)/corrective.

Q. One control for accountability and one for non-repudiation, with labels.
A. Protected audit logging: technical/detective. Digital signatures under a PKI: technical/preventive.

1.3 Actors and Attack Classes

A **hacker** is skilled; the *hat* is the intent and legality: **black** (criminal, for gain), **white** (authorised, finds and fixes), **grey** (works with organisations but not necessarily lawfully, e.g. tests without permission). By motive and resources: **state-related** (very high resources, espionage/intrusion), **cybercriminals** (high resources, money), **cyber-terrorists** (destruction), **hacktivists** (ideology, defacements), **script kiddies** (low skill, others' tools, amusement). The threat model needs both axes: script kiddies are defeated by patching; states buy unknown vulnerabilities.

Attack classes and the property each targets: **social engineering** (the person is the vulnerability); **DDoS** (bots in a botnet flood a target for hours to days: availability; hard to block because sources are many and look legitimate); **vulnerability exploits** (OWASP Top 10 lists web classes, Metasploit automates); **unauthorised access** by social engineering, brute force or **password cracking** (hashes already stolen, guesses tested *offline*: login rate limits are irrelevant, only per-guess cost and password entropy matter); **privilege abuse** (an insider, enabled by unnecessary privilege, i.e. no least privilege, and by missing logs, i.e. no accountability); **ransomware** (a payload: encrypt, demand the key's price).

Go deeper: the details an examiner asks about

- Grey hat is defined by method, not alternating intent; a white hat without authorisation is grey by this definition.
- A botnet is the product of a malware campaign and the instrument of an availability attack; the slides link the two.

Hard questions, answered

Q. Why does a six-character password survive online guessing with lockout but fall offline?
A. Online: a few tries per hour. Offline: $26^6 \approx 3 \times 10^8$ hashes computed in under a second against the stolen verifier; the only brake is the hash's per-guess cost.

Q. An admin reads customers' messages "to debug". Class and failed principles?
A. Privilege abuse; least privilege (debugging should not require content) and accountability (reads unlogged).

1.4 Malware by Mechanism

Vectors sit on an axis from *technical* (virus, macro virus, exploit, worm) to *social* (drive-by, clickjacking, phishing, spear phishing, trojan); the axis predicts the control (patching and integrity monitoring vs training and interface design).

Definition 1.4.1 (The families)**. Virus**: infects *programs*; modifies them to carry a copy; executes when the host runs, with the host's permissions (virus = host + execution). Components: infection mechanism (vector), trigger (a condition; a *logic bomb*), payload. **Macro virus**: document scripting (Melissa 1999: Word macro, mailed itself via Outlook; today macros carry warnings

and `.xlsm` extensions). **Worm**: seeks *machines*; each infected host attacks others; spreads by network (web-app upload bugs, SSH dictionary attacks), media (USB autostart) or social means; strategies: *random* scanning (noisy), *hit-list* (precompiled targets, stealthy; Stuxnet), *topological* (data on the victim), *local subnet* (behind NAT/firewall). Morris worm (1988): `fingerd` and `sendmail` bugs plus weak passwords; first CFAA (1986) conviction. **Rootkit**: with root privilege, modifies kernel code/data so the OS lies (`ps` hides a process); *not* an infection method but stealth and continued access; needs root obtained elsewhere; "runs at boot" alone is not a rootkit. **Drive-by download**: browser vulnerabilities install malware on a mere visit (Angler kit: visit, redirect, check, exploit, install). **Clickjacking**: input meant for one action performs another by timing (a dialog appears under the "puppy" 200 ms later) or circumstance (a transparent authorisation page over a game); Chapter 2. **Phishing**: impersonate a trusted source to induce an action (click, open, reply, change a setting, transfer money); *spear* phishing is targeted with facts from reconnaissance; Google Docs 2017: a fake share invitation led to an OAuth consent screen, no malware, the goal was *authorisation*. **Trojan**: the victim runs it (`adorablecat.jpg.exe`, fake ad, "install this plugin"); Zeus/Zbot banking trojan.

Key insight

Viruses infect executables to spread; worms infect machines to spread; trojans infect machines if you run them; rootkits infect kernels to avoid detection. Classical viruses are rare today because their one necessary act, modifying a binary, is cheaply prevented (no write access to program files) and detected (track binary hashes). Ransomware is a payload, not a vector.

Example 1.4.2 (Guess the type)**.** A: outdated Windows service exploited, automatic LAN scanning, 200,000 machines in 150 countries, files encrypted, Bitcoin ransom: a *worm* with a *ransomware* payload. B: a compromised accounting-software update, spreads by exploit *and* stolen credentials, ransom note but paying never recovers files: *supply-chain* delivery, *worm* propagation, *wiper* disguised as ransomware. Classify by mechanism, not by the note on the screen.

Technique: Phishing defences

Users: skepticism, limit what you publish (attacker's background material), inspect links, reach known services yourself. Organisations: training; chain-of-command procedures so an email is never a valid channel for critical requests; email link screening (see all clicks, spot trends, black-hole links at forwarding: detective turned corrective).

Go deeper: the details an examiner asks about

- Rootkit detection must come from outside the lying kernel (boot clean media, compare to known-good images).
- Hit-list = targeted + stealthy; random = fast + loud; the slides pair the words deliberately.

- Consent-screen phishing defeats "inspect the link"; organisation-side controls matter.

Hard questions, answered

Q. Hashing binaries stops viruses but not worms. Why?
A. A virus must modify executables (hash changes); a worm arrives as a new process via a network exploit and touches no existing program. Worm controls: patching, segmentation, credential hygiene.

Q. A program hides its files, survives reboot, came as an email attachment the user opened. Vectors and categories?
A. Phishing delivery of a trojan; persistence is ordinary; hiding files by altering OS answers is a rootkit component, which needed root (an exploit or the user running it as admin).

1.5 Domains, Access Control, GRC

Technical domains: network, web (applications, sessions, input), cryptography (encryption, hashing, signatures, PKI), access control (authentication, authorisation, least privilege), endpoint, cloud. Governance: GRC and privacy. **IAAA**: *identification* (claim an identity), *authentication* (prove it), *authorisation* (what it may do), *accountability* (log and audit). Each fails separately: a badge reader identifies the badge, not the holder (add a PIN); a logged-in user reaching `/admin` is an authorisation failure; a shared account defeats accountability. **GRC**: governance (direction, policies, roles, strategy), risk (identify, assess likelihood and impact, treat/accept/transfer/avoid, monitor), compliance (laws, standards, contracts, audits). Web model: `subdomain.mysite.com/folder/page?id=5`; GET fetches, POST submits.

Go deeper: the details an examiner asks about

- Least privilege lives in authorisation; privilege abuse is its failure.
- References to cite: Whitman & Mattord; Stallings & Brown; Anderson's *Security Engineering*; ISO/IEC 27001/27002; NIST; OWASP.

Hard questions, answered

Q. Map a TLS connection to a bank onto IAAA.
A. Identification: the server name; authentication: certificate chain (server) and password/MFA (user); authorisation: the account's permitted operations; accountability: transaction logs tied to the session.

Q. Cyber-insurance and refusing to store card numbers are which treatments?
A. Transfer; avoid.

Summary: Foundations

- Asset, property, adversary, control: all four or it is not a claim. Properties are independent; find the tampered object.

- Risk = threat × vulnerability on an asset; model before defending; treat/accept/transfer/avoid.
- Service = what, control = how; label controls by implementation *and* function.
- Malware by mechanism: virus (programs), worm (machines), trojan (user runs it), rootkit (kernel lies); social end exploits the person.
- IAAA; GRC.